

## PRICEWISE

Klypup Applied AI Intern — Technical Assessment

# API Contract

## Dynamic Pricing Intelligence Platform

---

|                |                                              |
|----------------|----------------------------------------------|
| SPECIFICATION  | OpenAPI 3.0.3                                |
| VERSION        | 1.0.0                                        |
| TRANSPORT      | REST over HTTPS + Server-Sent Events         |
| AUTHENTICATION | httpOnly cookies (access + rotating refresh) |
| TENANCY        | Organization-scoped, enforced at query level |
| BACKEND        | Bun + Express · Prisma · Postgres            |
| ENDPOINTS      | 19 paths · 18 schemas                        |

# 1. Overview

REST API for the multi-tenant, multi-agent dynamic pricing intelligence platform. All AI/LLM calls happen server-side only; the frontend never calls Groq directly. Auth uses httpOnly cookies (access + refresh), so most endpoints have no bearer token in the request — the cookie is sent automatically by the browser.

## 1.1 Servers

| Environment         | Base URL                           |
|---------------------|------------------------------------|
| Production (Render) | https://pricewise-api.onrender.com |
| Local development   | http://localhost:4000              |

## 1.2 Conventions

| Concern           | Contract                                                                                                                                                                                                                                                |
|-------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Response envelope | Every JSON response is wrapped. Success: { "success": true, "data": ... }. Failure: { "success": false, "error": { "code", "message", "details" } }.                                                                                                    |
| Authentication    | Access and refresh tokens are issued as httpOnly, Secure, SameSite=Lax cookies. JavaScript cannot read them. The browser attaches them automatically, so no Authorization header is used.                                                               |
| CSRF              | State-changing requests require the X-Pricewise-Client header set by the frontend client. A cross-site HTML form cannot set custom headers, so forged submissions are rejected before reaching a handler.                                               |
| Tenancy           | Tenant middleware resolves organizationId from the verified access token and injects it into request context. Every service-layer query filters on it. A resource belonging to another organization returns 404, never 403, so existence is not leaked. |
| Validation        | Request bodies are parsed with Zod schemas shared between frontend and backend. A failure returns 422 with field-level details.                                                                                                                         |
| Pagination        | Unbounded collections (recommendations, audit logs) use cursor pagination. Bounded collections (product catalog) use offset pagination with page/pageSize.                                                                                              |
| Rate limiting     | Authentication routes are limited more aggressively than general API routes. Exceeding a limit returns 429 with a Retry-After header.                                                                                                                   |
| Streaming         | Recommendation generation responds with text/event-stream rather than JSON, emitting one event per agent as the pipeline progresses.                                                                                                                    |

# 2. Endpoint index

Complete surface area of the API. Role column indicates the minimum role required; “Any” means any authenticated member of the organization.

| Method | Path                | Purpose                                               | Role   |
|--------|---------------------|-------------------------------------------------------|--------|
| POST   | /auth/signup        | Create a new organization and its first admin user    | Public |
| POST   | /auth/signup/invite | Join an existing organization via an invite code      | Public |
| POST   | /auth/login         | Log in with email + password                          | Public |
| POST   | /auth/refresh       | Rotate the refresh token and issue a new access token | Public |
| POST   | /auth/logout        | Revoke the current refresh token and clear cookies    | Any    |

| Method | Path                                          | Purpose                                                                                                                                                                                                                           | Role        |
|--------|-----------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| GET    | /auth/me                                      | Get the current authenticated user + organization                                                                                                                                                                                 | Any         |
| GET    | /org/settings                                 | Get organization settings (thresholds, margin floors)                                                                                                                                                                             | Any / Admin |
| PATCH  | /org/settings                                 | Update organization settings (admin only)                                                                                                                                                                                         | Any / Admin |
| GET    | /org/invites                                  | List pending invites (admin only)                                                                                                                                                                                                 | Admin       |
| POST   | /org/invites                                  | Create an invite code (admin only)                                                                                                                                                                                                | Admin       |
| GET    | /products                                     | List products in the current organization's catalog                                                                                                                                                                               | Any / Admin |
| POST   | /products                                     | Create a product (admin only)                                                                                                                                                                                                     | Any / Admin |
| GET    | /products/{productId}                         | Get a single product                                                                                                                                                                                                              | Any / Admin |
| PATCH  | /products/{productId}                         | Update a product (admin only)                                                                                                                                                                                                     | Any / Admin |
| DELETE | /products/{productId}                         | Delete a product (admin only)                                                                                                                                                                                                     | Any / Admin |
| POST   | /products/{productId}/simulate-market-event   | Mutate a product's competitor price or demand signal to simulate a live market event                                                                                                                                              | Any         |
| POST   | /products/{productId}/generate-recommendation | Trigger the 5-agent pricing pipeline for this product                                                                                                                                                                             | Any         |
| GET    | /recommendations                              | List pricing recommendations, cursor-paginated                                                                                                                                                                                    | Any         |
| GET    | /recommendations/{recommendationId}           | Get full detail including every agent's individual contribution                                                                                                                                                                   | Any         |
| POST   | /recommendations/{recommendationId}/approve   | Approve a pending recommendation (Pricing Analyst or Admin)                                                                                                                                                                       | Analyst+    |
| POST   | /recommendations/{recommendationId}/reject    | Reject a pending recommendation with a reason                                                                                                                                                                                     | Analyst+    |
| POST   | /recommendations/{recommendationId}/modify    | Override the recommended price with a manually chosen price                                                                                                                                                                       | Analyst+    |
| GET    | /audit-logs                                   | List audit log entries, cursor-paginated                                                                                                                                                                                          | Any         |
| POST   | /mock/ecommerce/update-price                  | Internal mock of an external e-commerce platform's price-update endpoint. Called only by the Execution & Compliance agent, never by the frontend. Simulates latency and an occasional induced failure to exercise rollback logic. | Internal    |

## 3. Endpoint reference

### 3.1 Auth

#### POST /auth/signup

Create a new organization and its first admin user

Auth: **public** — no session cookie required.

#### Request body

| Field            | Type   | Constraints            |
|------------------|--------|------------------------|
| email            | string | required; format email |
| password         | string | required; minLength 10 |
| name             | string | required               |
| organizationName | string | required               |

#### Responses

| Status | Payload       | Meaning                                          |
|--------|---------------|--------------------------------------------------|
| 201    | SuccessUser   | Account + organization created, auth cookies set |
| 409    | ErrorResponse | Email already in use                             |
| 422    | ErrorResponse | Validation error                                 |

#### POST /auth/signup/invite

Join an existing organization via an invite code

Auth: **public** — no session cookie required.

#### Request body

| Field      | Type   | Constraints            |
|------------|--------|------------------------|
| email      | string | required; format email |
| password   | string | required; minLength 10 |
| name       | string | required               |
| inviteCode | string | required               |

#### Responses

| Status | Payload       | Meaning                                  |
|--------|---------------|------------------------------------------|
| 201    | SuccessUser   | Joined organization, auth cookies set    |
| 400    | ErrorResponse | Invite invalid, expired, or already used |

**POST** /auth/login**Log in with email + password**Auth: **public** — no session cookie required.**Request body**

| Field    | Type   | Constraints            |
|----------|--------|------------------------|
| email    | string | required; format email |
| password | string | required               |

**Responses**

| Status     | Payload       | Meaning             |
|------------|---------------|---------------------|
| <b>200</b> | SuccessUser   | Auth cookies set    |
| <b>401</b> | ErrorResponse | Invalid credentials |
| <b>429</b> | ErrorResponse | Rate limited        |

**POST** /auth/refresh**Rotate the refresh token and issue a new access token**Auth: **public** — no session cookie required.**Responses**

| Status     | Payload        | Meaning                                    |
|------------|----------------|--------------------------------------------|
| <b>200</b> | SuccessMessage | New auth cookies set                       |
| <b>401</b> | ErrorResponse  | Refresh token missing, expired, or revoked |

**POST** /auth/logout**Revoke the current refresh token and clear cookies****Responses**

| Status     | Payload        | Meaning    |
|------------|----------------|------------|
| <b>200</b> | SuccessMessage | Logged out |

**GET** /auth/me**Get the current authenticated user + organization****Responses**

| Status     | Payload       | Meaning           |
|------------|---------------|-------------------|
| <b>200</b> | SuccessUser   | Current user      |
| <b>401</b> | ErrorResponse | Not authenticated |

## 3.2 Organizations

**GET** /org/settings

Get organization settings (thresholds, margin floors)

**Responses**

| Status | Payload         | Meaning               |
|--------|-----------------|-----------------------|
| 200    | SuccessEnvelope | Organization settings |

**PATCH** /org/settings

Update organization settings (admin only)

**Request body**

| Field               | Type   | Constraints          |
|---------------------|--------|----------------------|
| confidenceThreshold | number | maximum 1; minimum 0 |
| name                | string |                      |

**Responses**

| Status | Payload         | Meaning             |
|--------|-----------------|---------------------|
| 200    | SuccessEnvelope | Updated             |
| 403    | ErrorResponse   | Requires ADMIN role |

**GET** /org/invites

List pending invites (admin only)

**Responses**

| Status | Payload         | Meaning         |
|--------|-----------------|-----------------|
| 200    | SuccessEnvelope | List of invites |

**POST** /org/invites

Create an invite code (admin only)

**Request body**

| Field | Type   | Constraints            |
|-------|--------|------------------------|
| email | string | required; format email |
| role  | Role   | required               |

**Responses**

| Status | Payload         | Meaning             |
|--------|-----------------|---------------------|
| 201    | SuccessEnvelope | Invite created      |
| 403    | ErrorResponse   | Requires ADMIN role |

## 3.3 Products

**GET** /products

List products in the current organization's catalog

| Parameter | In    | Type    | Notes                                         |
|-----------|-------|---------|-----------------------------------------------|
| category  | query | string  |                                               |
| search    | query | string  |                                               |
| sortBy    | query | enum    | name, currentPrice, inventoryLevel, updatedAt |
| page      | query | integer | default 1                                     |
| pageSize  | query | integer | default 20                                    |

**Responses**

| Status | Payload         | Meaning                |
|--------|-----------------|------------------------|
| 200    | SuccessEnvelope | Paginated product list |

**POST** /products

Create a product (admin only)

**Request body**

ProductInput

**Responses**

| Status | Payload         | Meaning         |
|--------|-----------------|-----------------|
| 201    | SuccessEnvelope | Product created |

**GET** /products/{productId}

Get a single product

| Parameter | In   | Type   | Notes          |
|-----------|------|--------|----------------|
| productId | path | string | uuid; required |

**Responses**

| Status | Payload         | Meaning                                      |
|--------|-----------------|----------------------------------------------|
| 200    | SuccessEnvelope | Product                                      |
| 404    | ErrorResponse   | Not found or belongs to another organization |

**PATCH** /products/{productId}**Update a product (admin only)**

| Parameter | In   | Type   | Notes          |
|-----------|------|--------|----------------|
| productId | path | string | uuid; required |

**Request body**

ProductInput

**Responses**

| Status | Payload         | Meaning |
|--------|-----------------|---------|
| 200    | SuccessEnvelope | Updated |

**DELETE** /products/{productId}**Delete a product (admin only)**

| Parameter | In   | Type   | Notes          |
|-----------|------|--------|----------------|
| productId | path | string | uuid; required |

**Responses**

| Status | Payload     | Meaning |
|--------|-------------|---------|
| 204    | – no body – | Deleted |

**POST** /products/{productId}/simulate-market-event**Mutate a product's competitor price or demand signal to simulate a live market event**

| Parameter | In   | Type   | Notes          |
|-----------|------|--------|----------------|
| productId | path | string | uuid; required |

**Request body**

| Field        | Type   | Constraints                                                                                    |
|--------------|--------|------------------------------------------------------------------------------------------------|
| eventType    | string | required; enum: competitor_price_drop, competitor_price_increase, demand_spike, new_competitor |
| magnitudePct | number | e.g. -15 for a 15% competitor price drop                                                       |

**Responses**

| Status | Payload        | Meaning       |
|--------|----------------|---------------|
| 200    | SuccessMessage | Event applied |

**POST** **/products/{productId}/generate-recommendation****Trigger the 5-agent pricing pipeline for this product**

Response is a Server-Sent Events stream (Content-Type: text/event-stream). Events: {agent, status: "running"|"done"|"error", output?} for each of the 5 agents, followed by a final {type: "recommendation\_ready", data: PricingRecommendation} or {type: "recommendation\_failed", error}.

| Parameter | In   | Type   | Notes          |
|-----------|------|--------|----------------|
| productId | path | string | uuid; required |

**Responses**

| Status     | Payload           | Meaning                             |
|------------|-------------------|-------------------------------------|
| <b>200</b> | text/event-stream | SSE stream of agent progress events |

**3.4 Recommendations****GET** **/recommendations****List pricing recommendations, cursor-paginated**

| Parameter | In    | Type                 | Notes      |
|-----------|-------|----------------------|------------|
| status    | query | RecommendationStatus |            |
| cursor    | query | string               |            |
| limit     | query | integer              | default 25 |

**Responses**

| Status     | Payload         | Meaning                              |
|------------|-----------------|--------------------------------------|
| <b>200</b> | SuccessEnvelope | Cursor-paginated recommendation list |

**GET** **/recommendations/{recommendationId}****Get full detail including every agent's individual contribution**

| Parameter        | In   | Type   | Notes          |
|------------------|------|--------|----------------|
| recommendationId | path | string | uuid; required |

**Responses**

| Status     | Payload         | Meaning                             |
|------------|-----------------|-------------------------------------|
| <b>200</b> | SuccessEnvelope | Recommendation with agent breakdown |

**POST** /recommendations/{recommendationId}/approve

Approve a pending recommendation (Pricing Analyst or Admin)

| Parameter        | In   | Type   | Notes          |
|------------------|------|--------|----------------|
| recommendationId | path | string | uuid; required |

**Responses**

| Status | Payload         | Meaning                                               |
|--------|-----------------|-------------------------------------------------------|
| 200    | SuccessEnvelope | Approved and executed against the mock e-commerce API |

**POST** /recommendations/{recommendationId}/reject

Reject a pending recommendation with a reason

| Parameter        | In   | Type   | Notes          |
|------------------|------|--------|----------------|
| recommendationId | path | string | uuid; required |

**Request body**

| Field  | Type   | Constraints           |
|--------|--------|-----------------------|
| reason | string | required; minLength 3 |

**Responses**

| Status | Payload         | Meaning  |
|--------|-----------------|----------|
| 200    | SuccessEnvelope | Rejected |

**POST** /recommendations/{recommendationId}/modify

Override the recommended price with a manually chosen price

| Parameter        | In   | Type   | Notes          |
|------------------|------|--------|----------------|
| recommendationId | path | string | uuid; required |

**Request body**

| Field         | Type   | Constraints                  |
|---------------|--------|------------------------------|
| modifiedPrice | number | required; exclusiveMinimum 0 |

**Responses**

| Status | Payload         | Meaning               |
|--------|-----------------|-----------------------|
| 200    | SuccessEnvelope | Modified and executed |

## 3.5 Audit

**GET** /audit-logs

List audit log entries, cursor-paginated

| Parameter  | In    | Type    | Notes      |
|------------|-------|---------|------------|
| entityType | query | string  |            |
| cursor     | query | string  |            |
| limit      | query | integer | default 25 |

**Responses**

| Status     | Payload         | Meaning                    |
|------------|-----------------|----------------------------|
| <b>200</b> | SuccessEnvelope | Cursor-paginated audit log |

### 3.6 Mock Ecommerce

**POST** /mock/ecommerce/update-price

Internal mock of an external e-commerce platform's price-update endpoint. Called only by the Execution & Compliance agent, never by the frontend. Simulates latency and an occasional induced failure to exercise rollback logic.

**Request body**

| Field    | Type   | Constraints |
|----------|--------|-------------|
| sku      | string | required    |
| newPrice | number | required    |

**Responses**

| Status     | Payload        | Meaning                                            |
|------------|----------------|----------------------------------------------------|
| <b>200</b> | SuccessMessage | Price updated on the (mock) platform               |
| <b>502</b> | ErrorResponse  | Simulated platform failure — caller must roll back |

## 4. Schema reference

Every schema below is generated from the Zod definitions in `packages/shared`, which are the same objects used for runtime request validation. The contract therefore cannot drift from the implementation.

### Role

Enum (string): ADMIN, PRICING\_ANALYST

### RecommendationStatus

Enum (string): PENDING, APPROVED, REJECTED, MODIFIED, AUTO\_EXECUTED, FAILED

### InventoryStatus

Enum (string): LOW, NORMAL, OVERSTOCKED

### ErrorResponse

| Field   | Type    | Notes         |
|---------|---------|---------------|
| success | boolean | example False |
| error   | object  |               |

### SuccessEnvelope

| Field   | Type    | Notes        |
|---------|---------|--------------|
| success | boolean | example True |

### SuccessMessage

Extends: SuccessEnvelope

| Field   | Type   | Notes |
|---------|--------|-------|
| message | string |       |

### SuccessUser

Extends: SuccessEnvelope

| Field | Type   | Notes |
|-------|--------|-------|
| data  | object |       |

### OffsetPagination

| Field      | Type    | Notes |
|------------|---------|-------|
| page       | integer |       |
| pageSize   | integer |       |
| totalCount | integer |       |
| totalPages | integer |       |

### CursorPagination

| Field      | Type    | Notes    |
|------------|---------|----------|
| nextCursor | string  | nullable |
| hasMore    | boolean |          |

## User

| Field          | Type   | Notes     |
|----------------|--------|-----------|
| id             | string | uuid      |
| email          | string | email     |
| name           | string |           |
| role           | Role   |           |
| organizationId | string | uuid      |
| createdAt      | string | date-time |

## Organization

| Field               | Type   | Notes     |
|---------------------|--------|-----------|
| id                  | string | uuid      |
| name                | string |           |
| confidenceThreshold | number |           |
| createdAt           | string | date-time |

## Invite

| Field     | Type   | Notes               |
|-----------|--------|---------------------|
| id        | string | uuid                |
| email     | string | email               |
| role      | Role   |                     |
| code      | string |                     |
| expiresAt | string | date-time           |
| usedAt    | string | date-time; nullable |

## ProductInput

| Field          | Type    | Notes                          |
|----------------|---------|--------------------------------|
| sku            | string  | required                       |
| name           | string  | required                       |
| category       | string  | required                       |
| currentPrice   | number  | required                       |
| cost           | number  | required                       |
| marginFloorPct | number  | required; minimum 0; maximum 1 |
| inventoryLevel | integer | required                       |

## Product

Extends: ProductInput

| Field           | Type            | Notes     |
|-----------------|-----------------|-----------|
| id              | string          | uuid      |
| organizationId  | string          | uuid      |
| inventoryStatus | InventoryStatus |           |
| createdAt       | string          | date-time |
| updatedAt       | string          | date-time |

## PricingRecommendation

| Field              | Type                 | Notes                |
|--------------------|----------------------|----------------------|
| id                 | string               | uuid                 |
| productId          | string               | uuid                 |
| recommendedPrice   | number               |                      |
| currentPriceAtTime | number               |                      |
| confidenceScore    | number               | minimum 0; maximum 1 |
| rationale          | string               |                      |
| status             | RecommendationStatus |                      |
| resolvedByUserId   | string               | uuid; nullable       |
| resolvedAt         | string               | date-time; nullable  |
| rejectionReason    | string               | nullable             |
| modifiedPrice      | number               | nullable             |
| createdAt          | string               | date-time            |

## AgentRun

| Field      | Type    | Notes                                                                                                 |
|------------|---------|-------------------------------------------------------------------------------------------------------|
| agentName  | string  | enum: MARKET_INTELLIGENCE, DEMAND_FORECASTING, INVENTORY_COST, PRICING_STRATEGY, EXECUTION_COMPLIANCE |
| input      | object  |                                                                                                       |
| output     | object  |                                                                                                       |
| durationMs | integer |                                                                                                       |
| createdAt  | string  | date-time                                                                                             |

## PricingRecommendationDetail

Extends: PricingRecommendation

| Field     | Type            | Notes |
|-----------|-----------------|-------|
| agentRuns | array<AgentRun> |       |

AuditLog

| Field       | Type   | Notes          |
|-------------|--------|----------------|
| id          | string | uuid           |
| userId      | string | uuid; nullable |
| action      | string |                |
| entityType  | string |                |
| entityId    | string |                |
| beforeValue | object | nullable       |
| afterValue  | object | nullable       |
| createdAt   | string | date-time      |

## 5. Error codes

| Code             | HTTP | When it occurs                                                                                  |
|------------------|------|-------------------------------------------------------------------------------------------------|
| VALIDATION_ERROR | 422  | Request body or query failed Zod validation. details carries field-level messages.              |
| UNAUTHENTICATED  | 401  | Access cookie absent, malformed, or expired. Client should call /auth/refresh once, then retry. |
| REFRESH_INVALID  | 401  | Refresh token expired, already rotated, or revoked. Client must re-authenticate.                |
| FORBIDDEN_ROLE   | 403  | Authenticated, but the role lacks permission for this route.                                    |
| NOT_FOUND        | 404  | Resource does not exist, or belongs to another organization. Deliberately indistinguishable.    |
| EMAIL_IN_USE     | 409  | Signup attempted with an email already registered.                                              |
| INVITE_INVALID   | 400  | Invite code unknown, expired, or already redeemed.                                              |
| RATE_LIMITED     | 429  | Rate limit exceeded for this route class. Retry-After header indicates when to retry.           |
| AGENT_TIMEOUT    | 504  | An agent exceeded its per-call timeout after retries. Recommendation marked FAILED.             |
| LLM_UNAVAILABLE  | 503  | Groq API unreachable or rate limited beyond backoff budget.                                     |
| EXECUTION_FAILED | 502  | Mock e-commerce platform rejected the price update. Change rolled back.                         |
| INTERNAL_ERROR   | 500  | Unhandled exception. Logged with a correlation id returned in the message.                      |

## 6. Streaming contract

POST /products/{productId}/generate-recommendation does not return JSON. It holds the connection open and emits Server-Sent Events as the agent pipeline executes, so the client can render per-agent progress instead of a single spinner.

| Event                 | Payload                                   | Meaning                                                                              |
|-----------------------|-------------------------------------------|--------------------------------------------------------------------------------------|
| agent_started         | { agent, startedAt }                      | Emitted as each agent begins. Five of these per run.                                 |
| agent_completed       | { agent, durationMs, output, confidence } | Agent finished and its output passed schema validation.                              |
| agent_failed          | { agent, error, willRetry }               | Agent call errored. willRetry indicates backoff is in progress.                      |
| recommendation_ready  | { recommendation, autoExecuted }          | Terminal success event. autoExecuted true when confidence cleared the org threshold. |
| recommendation_failed | { error, failedAgent }                    | Terminal failure event. A FAILED row is persisted for the audit trail.               |

### Example wire format

```

event: agent_started
data: {"agent":"MARKET_INTELLIGENCE","startedAt":"2026-09-16T18:04:11.204Z"}

event: agent_completed
data: {"agent":"MARKET_INTELLIGENCE","durationMs":1840,"confidence":0.91,
"output":{"competitorMin":268.00,"competitorMedian":289.99,"trend":"falling"}}

event: recommendation_ready
data: {"autoExecuted":false,"recommendation":{"id":"...", "recommendedPrice":279.99,
"confidenceScore":0.87,"status":"PENDING"}}

```